

Article

Security Aspects of Zones and Conduits in IEC 62443 [†]

Martin Gilje Jaatun ^{1,*}, Mary Ann Lundteigen ^{2,*}, Christoph Thieme ¹, Lars Halvdan Flå ¹,
Karin Bernsmed ¹, Roald Lygre ³ and Fredrik Gratte ⁴

¹ Department of Software Engineering, Safety and Security, SINTEF Digital, P.O. Box 4760, Torgarden, 7465 Trondheim, Norway

² Department of Engineering Cybernetics, Norwegian University of Science and Technology, 7491 Trondheim, Norway

³ Aker BP, P.O. Box 480, Sentrum, 4002 Stavanger, Norway; roald.lygre@akerbp.com

⁴ Atina, Økonomisenteret, P.O. Box 70, 3441 Røyken, Norway

* Correspondence: martin.g.jaatun@sintef.no (M.G.J.); mary.a.lundteigen@ntnu.no (M.A.L.)

[†] This paper is an extended version of our paper published in Flå, L.H.; Lundteigen, M.A.; Gratte, F.; Jaatun, M.G. Implementation of Zones and Conduits in Industrial Control and Automation Systems. Presented at the International Conference on Cybersecurity, Situational Awareness and Social Media, Edinburgh, Scotland, 27–28 June 2024; pp. 367–382. Published by Springer Nature Singapore in April 2025.

Abstract

The IEC 62443 standard defines that, based on risk assessment, different parts of an Industrial Automation and Control System (IACS) may have different security levels, and that parts with the same security level can be designated as separate zones. Furthermore, communication between different zones, both intra-IACS and inter-IACS, can be done via conduits. In this article, we argue that zones and particularly conduits can benefit from more detailed discussions of their architecture and implementation. Consequently, as novel contributions we (1) describe detailed principles for implementing conduits; (2) outline a process for connecting zones with potentially different Security Levels (SLs), expressed in the form of a flow chart; and (3) discuss challenges related to the application of zones and conduits in practice.

Keywords: cybersecurity; operational technology; industrial control systems; industrial automation and control system; IEC 62443; security level; zones and conduits

1. Introduction

IEC 62443 [1] is the globally preferred standard for cybersecurity concepts and requirements for industrial automation and control systems (IACSs). The standard consists of several parts as shown in Table 1, where those marked “TS” are technical specifications with the status as guidance only.

IEC 62443 suggests a risk-based analysis to segment the network architecture into (i) *zones*, representing a set of network assets that share common needs for protection; and (ii) *conduits*, which identify how zones are connected. Establishing zones and conduits during a cybersecurity risk analysis is a key activity when securing industrial control systems in accordance with IEC 62443, as the risk analysis defines security requirements and security level (SL) targets (SL-T) at this level. The zones can be organized geographically and/or according to main asset functionalities.

IEC 62443 defines four distinct security levels, where SL-1 is the lowest level and SL-4 is the highest level of protection. The security level requirements are grouped into seven foundational requirement (FR) categories, and the standard identifies which requirements



Academic Editor: Georgios Kambourakis

Received: 30 December 2025

Revised: 5 March 2026

Accepted: 6 March 2026

Published: 12 March 2026

Copyright: © 2026 by the authors.

Licensee MDPI, Basel, Switzerland.

This article is an open access article distributed under the terms and conditions of the [Creative Commons Attribution \(CC BY\)](https://creativecommons.org/licenses/by/4.0/) license.

must apply to each SL-T. Applicable requirements are adopted for each system within the zone according to an SL vector where each FR is identified.

Table 1. The parts that comprise IEC 62443 series.

Number	Name	Year	Status
TS 62443-1-1	Terminology, concepts, and models	2009	Published (newer draft exists)
62443 1-3	System security compliance metrics	2021	Withdrawn
62443-1-5	Security profiles	2023	Published
62443-2-1	Establishing an industrial automation and control systems security program	2024	Published
62443-2-2	IACS security protection scheme	2025	Publicly Available Specification
62443-2-3	Patch management in the IACS environment	2015	Published (newer draft exists)
62443-2-4	Security program requirements for IACS service providers	2023	Published
62443-3-1	Security technologies for industrial automation and control systems	2009	Published
62443-3-2	Security risk assessment for system design	2020	Published
62443-3-3	System security requirements and security levels	2019	Published
62443-4-1	Secure product development lifecycle requirements	2018	Published
62443-4-2	Technical security requirements for IACS components	2019	Published
TS 62443-6-1	Security evaluation methodology for IEC 62443-2-4	2024	Published
TS 62443-6-2	Security evaluation methodology for IEC 62443-4-2	2025	Published

However, IEC 62443 is currently vague about how these requirements apply to conduits, and this may be because the standard is not precise about what constitutes a conduit or which software and hardware are included. It is necessary to explore industry practice and investigate how requirements for conduits may be understood within the context and intent of the standard. The literature on addressing security in IACS provides little clarification, mostly focusing only on the segmentation [2,3] and not on the conduits that transfer the flow. Kern et al. [4] and Schlehuber et al. [5] apply some principles that implicitly apply to conduits.

Therefore, this article aims to clarify the concept of conduits, including their boundaries, and to propose a set of principles for how security requirements are impacted by the zones they connect. This research is a development of our previous paper [6], building on further exploration of the standard and interactions with the industry. For example, there are several IACS networks where the allocation to zone or conduit of individual components or component functions in the network structure is sometimes unclear. Having a well-defined specification of zone boundaries and a secure, well-managed communication through conduits will help to assess the criticality of vulnerabilities when they become known, and aid their subsequent handling. Identifying all conduits and data flows will also facilitate monitoring of IACS communication networks and their protection against malicious communication.

The proposed set of principles addresses:

1. Visualization of a generalized zone and conduit architecture.
2. Approach to managing security requirements for conduits, considering conduits connecting zones with different SLs as well as zones with identical SLs.

3. Considerations related to SL allocation and verification.

The remainder of this article is structured as follows: Section 2 presents related work. Section 3 explains the methodology employed in the research documented in this article. Section 4 describes the process of assigning and verifying security levels. Section 5 presents relevant concepts from the IEC 62443 standard. Section 6 describes proposed architectural principles for implementing conduits. Section 7 presents a process for the secure connection of zones with different SLs, whereas Section 8 looks at the case of connecting different zones with the same security level. Section 9 discusses practical challenges of implementing zones and conduits in practice. Section 10 concludes this paper, and Section 11 describes further work.

2. Related Work

The most important influence on industrial automation and control system architecture for cybersecurity is the Purdue model [7], illustrated in Figure 1. This model originated at Purdue University in the 1990s, and despite not being created with cybersecurity in mind, it has seen wide adoption within cybersecurity for industrial control systems. The Purdue model splits a plant's network and systems into 5–6 levels, with a clear separation of the operational technology (OT) side for plant operation, monitoring, data acquisition, and the IT side with the office networks and externally connected cloud solutions and applications. Each level can be viewed as a subdivision of the network, grouping systems that share common operational functions. The levels are often a helpful starting point for a coarse segmentation of networks, with a more detailed segmentation made within each level as appropriate. The International Society of Automation (ISA) adopted a similar model in its ISA-95 family of standards on integrating logistics systems with manufacturing control systems, and the Purdue model is therefore also referred to as the ISA-95 model.

Variants of the Purdue model incorporating the security aspects are illustrated in IEC 62443 and in ISA TR 84.00.09 [8], the ISA guide on application of IEC 62443 for IACS systems defined as critical for safety. There are also several whitepapers and product supplier reference guides for IACS cybersecurity network design that are based on the same model. An example of a product supplier reference guide is the Industrial Automation Security Design Guide 2.0 from Cisco [9], which has a chapter on segmenting the network into smaller trust zones. This document (which refers to the IEC 62443 standard) defines a zone as “a collection of physical and functionally united assets that have similar security requirements”. In addition to zone characteristics already known from IEC 62443, they specify that a zone defines the access boundary towards other zones or the outside world, whereas a conduit supports and defines allowed communication between two or more zones. Suggested attributes of a conduit include the zones it interconnects, the type of data flow permitted, and the security policies and procedures in place. With regard to the segmentation of OT networks, the document argues that area zones provide a good starting point. As more insights to plant operations become available, the initial segmentation can later be extended by further segmentation using Virtual Local Area Network (VLAN) segments. It is highlighted in the Cisco guide that segmentation increases complexity, and an example is provided where a particular security measure had to be considered for a total of 400 zones. The issue of complexity caused by extensive segmentation is further discussed in Section 9.

Combining zones and conduits within a Purdue reference architecture may be regarded as a “defence in depth” strategy. For example, DesRuisseaux [2] argues that proper defence in depth involves six steps. The first step is to make a security plan. Step two involves separating networks by major function, and as example lists that a network can be divided into enterprise, plant, process, and field zones. Subsequently, all conduits between

zones should be identified. In step three, named perimeter protection, these conduits should be protected. In step four, referred to as network segmentation, existing zones can be divided into smaller zones. This division can be based on location or function. The last two steps involve device hardening and continuous monitoring, which will not be discussed further here.

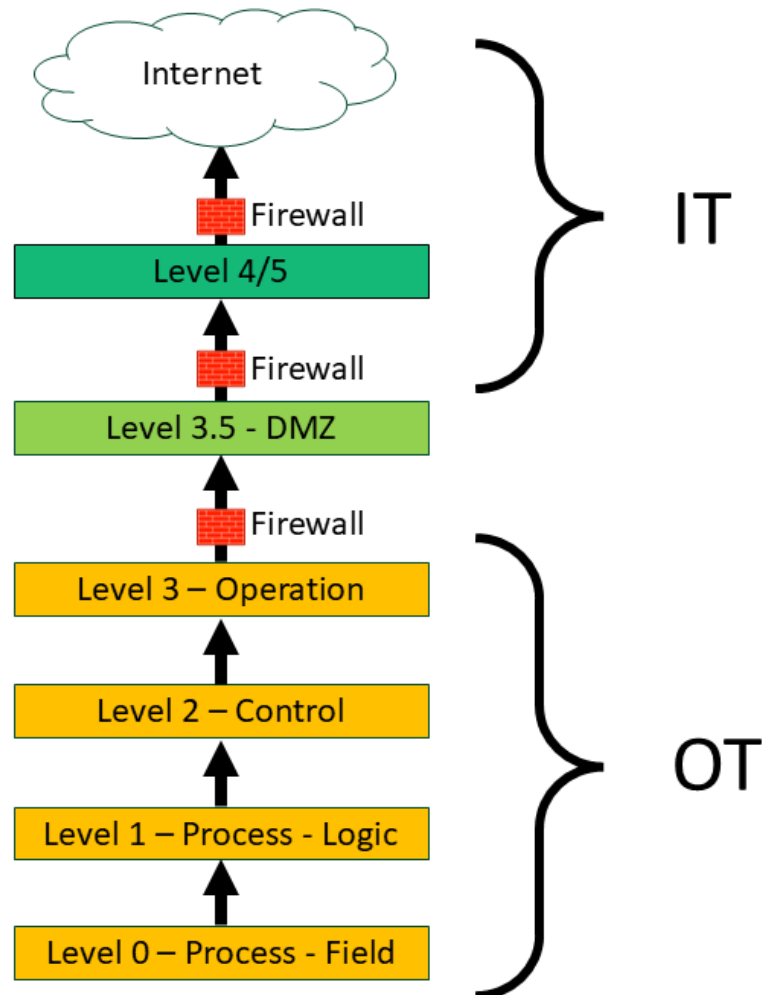


Figure 1. The Purdue model.

Leander et al. [3] discuss the applicability of IEC 62443 in light of the expected transition to Industry 4.0 and increased use of Industrial Internet of Things (IIoT) devices. Specifically, regarding IEC 62443 zones, they argue that this concept may be challenged by IIoT devices relying on, for instance, cloud access and by the dynamic nature of Software Defined Networking.

Most requirements and discussions are made common for zones and conduits, without clarifying how the two types of segmentation are treated differently in practice. One exception is the European technical specification CLC/TS 50701 on railway cybersecurity [10], which has an annex (A) dedicated to handling conduits. Here, it is suggested that there are only three types of conduits:

1. Conduits implementing a transparent (i.e., logical) gateway connecting zones of the same SL.
2. Filtering conduits as firewall appliance, allowing a zone of lower or equal security to communicate with a zone of a higher SL.

3. Unidirectional conduit as a data diode or network tap, allowing for output from a higher SL zone to others.

Here, the conduits may relate to logical functions implemented with the network devices and not necessarily the hardware involved. The technical specification comments that IEC 62443 does not clearly advise on whether network devices should be part of zones or conduits, and an interpretation is that a network device acting as a boundary protection of a zone can belong to the zone as well as to the conduit.

Soderi et al. [11] have interpreted the practical application of CLC/TS 50701 when the conduit is a wireless communication within a train control system. Here, they assume that the connected zones have the same SL, meaning that a transparent gateway is the preferred type of conduit. In wireless communication, additional measures are needed to achieve transparency when exposed to cyber attacks. Their solution is to use a host identify protocol (HIP) that provides transparency with end-to-end encryption, mutual authentication, and internet protocol security.

Kern et al. [4] have modeled and made an UML-like visualization of an architecture of zones, data flows, and their related attributes and functions, following the basic requirements in IEC 62443. In their work, they consider conduits as the means of transporting data flows and they argue that the SL assigned to network components is determined by the highest SL assigned to the data flow that runs through them. Their interpretation means that the SL-T of a zone is determined by the highest SL of the network components within that zone, even if the cybersecurity risk analysis suggested a lower SL-T.

Schlehuber et al. [5] propose an application layer gateway (ALG) to tackle the challenge when conduits are connecting zones with different SL requirements. An ALG can be configured to allow for the desired type of connection (or layer) to connect specific zones. The configuration may include whitelist filtering for each of the implemented layers. The ALG is also envisioned to be able to forward traffic to a Security Operations Centre (SOC) for analysis. This solution of including an ALG implies that the same conduit can be used to provide different levels of security, depending on the direction of the data flow.

3. Methodology

The primary research approach has been iterative empirical research: iterative, in the sense of exploring the identified industrial challenges with increasing depth; and empirical, in the sense of collecting information from various sources: the review and analysis of standards and guidelines, and workshops with subject-matter experts in relation to professional arenas. The experts and professional arenas have been limited to the oil and gas industry, such as the CDS forum [12] and the recently completed research project on Cybersecurity Barrier Management [13]. The challenges, industry practices, and possible solutions have been discussed in four workshops in relation to the CBM project and the CDS forum organizing committee (see Table 2 for an overview of the background of the committee members). Further, one plenary presentation was made to the CDS forum where a wider audience could give their feedback and comments.

Unlike zones, conduits are less well-defined in terms of the systems included. Conduits are physical and/or logical carriers shared by possibly several zones. Our starting point has been to evaluate whether a common set of security requirements to zones and conduits is applicable and, if so, how the SL requirement is practically applied to conduits. More specifically, the research questions that are explored in this research are:

- Should a conduit be limited to connecting two, and not several, zones?
- Is the SL requirement of a conduit derived from the SL requirements of the connecting zones only, or are other factors contributing?
- What are the practical implications of having SL requirements in relation to a conduit?

Table 2. Expertise in the CDS forum organizing committee.

Expertise Area	Number of Participants
Oil Company	3
Industrial Technology Provider	2
Assurance and Risk Management Provider	1
Regulatory Expert	1
Industrial Safety Scientist	2
Cyber Security Scientist	1

Interviews have not been carried out, as the workshop format was found to be most applicable. Even if the focus has been on the oil and gas sector, the insights should be transferable to other sectors that apply IEC 62443.

Although no separate pilot study has been carried out as part of the project, the results presented are derived from experiences with implementing zones and conduits in a representative oil company. The findings were fed back into the company, following the iterative approach of our study. For confidentiality reasons, we cannot share more details at this time.

The proposed recommendations in this article have been validated through review by subject-matter experts. Formal testing was not possible. Validation in which the solution is implemented more widely has not been done, as such implementation would require access to infrastructure that is not easily available. Instead, the focus has been on assessing practicality while ensuring compliance with IEC 62443.

4. Security Levels

Allocation of security levels is described in the detailed risk assessment in 62443 part 3-2 [14]. In this process, determining a security level target is a step that precedes determining consequences, impact and unmitigated likelihood (among other relying on identified threats and vulnerabilities). A substantial part of arriving at a suitable method for allocating security levels is therefore to determine optimal ways in which the steps leading up to the security level target can be performed.

The IACS Automation Solution Security Lifecycle as described by ISA GCA [15] does not seem to include a process for selecting IACS components (products) based on security requirements; rather, it is implied that components are simply chosen by “someone”, and the resulting system is then assessed. If the chosen components do not offer a sufficient security level, compensating organizational and technical security measures are expected to take up the slack. Annex A of IEC 62443-3-3 [16] does, however, mention “choosing a different component” as a possible compensating measure.

4.1. Security Level Verification

By security level verification, we refer to the process of determining the security level of what is implemented; that is, the level of security offered by the implemented technical security controls. Using IEC 62443 terminology, security level verification is the process of determining the security levels implemented at $t = 0$.

Annex A of IEC 62443-3-2 states that the design is typically an iterative process, where, for each iteration, the SL-A (now superseded by SL-I) is measured and compared to the SL-T. How this measurement and comparison should be performed is not evident from the standard. It does in one instance suggest that the system requirement from 62443-3-3 can play a role but does not detail it further.

A long-term goal of the IEC 62443 standard is to move towards quantitative descriptions of security levels. The now-withdrawn IEC 62443-1-3 draft (2021) suggests a

methodology for deriving quantitative measurement metrics. While the draft acknowledges that KPIs and performance metrics can be defined for all stages of the security life cycle, the draft specifies that the presented methodology is intended for measuring security controls implemented by the security program.

The draft makes the distinction between conformance metrics and performance metrics. Conformance metrics are binary and are intended to compare actual outcomes with expected outcomes. The role of conformance metrics with regards to requirements does, however, appear unclear. While the draft states that “[...] this work is not aimed to measure conformance with requirements of ISA 62443 standards”, it also states that “[...] the expectation is that each requirement considered in scope and applicable must be met in full to achieve conformance [...]”.

Performance metrics are intended to measure performance gains using observable attributes. The draft goes on to claim that most IEC 62443 requirements can be numerically measured using observable attributes. To illustrate the proposed methodology, the draft uses requirement ORG 1.4 Security awareness training from the IEC 62443-2-1 draft (2021) as an example. This requirement states that all personnel shall receive security awareness training, and that this training shall be updated regularly. Based on this requirement, the draft proposes two metrics:

- Cyber security awareness training: (Number of people who completed training)/(total number of people).
- Cyber security awareness training update: (Update frequency in days)/(Update frequency in days + days above the update frequency).

KPIs and performance metrics should ideally be measurable, repeatable, context specific, actionable, quantifiable, and manageable.

An important aspect of security level verification is to identify and consider all the factors that can influence the security level. IEC 62443-1-1 claims that several factors can influence the implemented security level of a zone or conduit, and illustrates this point with the following equation:

$$SL(implemented) = f(t, x_1, x_2, x_2, \dots, x_n) \quad (1)$$

where t is the time, and $x_1, \dots, x_n$ are factors, including, but not limited to:

- Capability and effectiveness of countermeasures.
- Inherent security properties of devices and systems within a zone or conduit. For individual components, this can be documented in the form of SL-C.
- Achieved SL of other zones communicating with the zone.
- Security properties of conduits are used to communicate with other zones.
- Audit and test intervals of countermeasures and security properties of devices and systems in the zone.
- Attacker expertise and available resources.
- Intrusion detection.

For the verification of security levels, it is natural that this happens within the already defined process of determining Security Protection Rating (SPR) as described in IEC 62443-2-2 [17]. This process takes system security requirements for zones/conduits and technical security measures as input, and results in a security level value. However, further detail on how this can be performed is not provided.

One option is to make the verification quantifiable using metrics. As stated above, the withdrawn IEC 62443-1-3 draft (2021) argues that several of the requirements in the standard can be numerically measured. While numerical metrics can make security more quantifiable and comparable, we would like to highlight the danger that reducing every-

thing to numbers could lead to concealing the absence of important requirements. We are unsure of both how easy to implement and how suitable quantifiable verification may be, and all proposed drafts of IEC 62443-1-3 have been rejected.

4.2. *SL Vector*

The security level for a zone or conduit can possibly be expressed as either a single value or as a vector. In Annex A of IEC 62443-3-3, the argument is made that due to the complexity of security systems, it is hard to express security levels with a single number. The alternative to the single security level value is a vector, with one security level value for each foundational requirement. The foundational requirements [1] are:

FR1: Identification and Authentication Control.

FR2: Use Control.

FR3: System Integrity.

FR4: Data Confidentiality.

FR5: Restricted Data Flow.

FR6: Timely Response to Events.

FR7: Resource Availability.

The requirements in IEC 62443-3-3 are organized according to these foundational requirements, allowing for a clear mapping between a security level vector and concrete requirements. However, the standard does not explain how the vector can be used when determining a security protection rating, as this would require a single value.

Throughout much of the standard, security levels are referred to as a single value. The one exception from this is Annex A in IEC 62443-3-3 (2019), where the concept of a security level vector is introduced. The security vector allows for a more fine-grained specification of the security capabilities of zone, as it specifies a security level value for each of the seven foundational requirements. As an example, we can have a zone which meets the requirements related to identification and authentication necessary to claim security level 3 while meeting the requirements for resource availability necessary to claim security level 1.

An obvious challenge associated with using the security vector approach is how to transform the vector into a value which is needed, for instance, when determining the security protection rating. A conservative approach would be to set the security level to the minimum value of the elements in the vector. Setting the security level to the mean value of the elements in the vector would be another approach. However, regardless of approach, collapsing a security vector into a single value can in many cases result in an inaccurate picture of the security capabilities implemented in the zone.

We are unsure of to what degree the concept of security level as a vector has been adopted by the industry, but we are aware of at least one instance where it has been used. In that instance, the motivation for using the vector was to reduce the number of requirements. It was concluded that by increasing the number of requirements in one of the foundational requirement categories, requirements in other categories could be removed or implemented on fewer components. As an example, by implementing stricter requirements related to segregation, firewalls, and by enforcing access via designated workstations, other requirements related to embedded devices could be removed.

4.3. *Maturity Levels*

IEC 62443-1-1 [1] defines maturity levels as “a qualitative method of characterizing the efficiency of an organization to implement security requirements according to documented

policies and procedures”. The standard defines what the various levels of maturity mean for product suppliers, system integrators and asset owners in part 4-1 [18], part 2-4 [18], and part 2-1 [19] respectively. As the maturity levels of asset owners are the most relevant for the scope of this article, we include a shortened version of the definitions from 62443-2-1 in Table 3.

Table 3. Maturity levels.

Maturity Level	Description
1	Processes are ad hoc and frequently not documented
2	Processes are documented
3	Documented processes are repeated over time
4	Effectiveness of the repeatable processes can be demonstrated and improved

While the standard does define what the different maturity levels mean for product suppliers, system integrator and asset owners, the standard gives little information related to allocation and verification of these levels. IEC 62443-1-1 [1] discusses maturity of a security program on a high abstraction level but does not offer any concrete guidance on how to determine a maturity level that can be used to determine Security Protection Rating. 62443-2-1 [19] does not detail maturity levels but expresses an expectation that there will be regular audits that confirm that procedures are being followed and that expected technical controls are in place.

An interesting implication of the way maturity levels 3 and 4 are defined (processes must be repeatable over time and improving) is that in order to claim this, an audit process at $t > 0$ is likely required. Therefore, the maturity level at $t = 0$ might not be determinable beyond ML 2, and consequently there will be no SPR at $t = 0$.

4.4. Security Protection Rating

IEC 62443 [20] intimates that Security is something that is provided/ensured by a security program, which is defined by a cybersecurity requirement specification, which is implemented by a set of measures in a security protection scheme, which can be classified according to a security protection rating.

The cybersecurity requirement specification is, according to IEC 62443-2-2 [17], derived based on parts 2-1 [19] and 3-2 [14]. This specification organizes requirements according to zones, and according to Security Program Elements (SPEs). This results in a structure where, for each zone, there is a set of requirements grouped according to SPE1, SPE2, ..., SPE_n. Each SPE, in turn, holds applicable requirements from 62443-2-1 [19], applicable general security requirements, and requirements from 62443-3-3 [16]. “General security requirements” are requirements specific to the IACS in consideration. They may, for instance, originate from company-specific policies, standards, or from regulatory requirements.

IEC 62443-2-2 [17] intends to provide guidance on the development and validation of the security protection scheme. The security protection scheme consists of both technical and process security measures, and inputs to these measures come from the cybersecurity requirements specification. Some security measures may be relevant only to one zone, while others may be relevant to several zones.

The security protection rating indicates to what degree the Security Protection Scheme complies with requirements. 62443-2-2 proposes a methodology for determining SPR, consisting of three steps. Step 1 is to assess the fulfilment of process security requirements, both from 2-1 and general security requirements. It also appears as if the maturity of the processes is assessed. Step 2 is to assess the requirements from 3-3, which can be fulfilled by technical security measures. The step results in a security level value. Step 3

assesses the fulfilment of requirements in 3-3 by process measures “leveraging technical security measures.” In addition to assessing fulfilment of requirements, the maturity of the processes is also assessed. It follows from this methodology that the security level of a zone or conduit may be achieved through a combination of technical security measures and process security measures.

The Security Protection Rating (SPR) is defined as a combination of Security Level (SL) and Maturity Level (ML), but as indicated in Table 4, the ML needs to be “practiced” (ML 3) or “improving” (ML 4), and whether it is ML 3 or ML 4 does not influence the SPR. The maturity level relates to how process security measures are performed as part of the Security Protection Scheme in operation. There is also an SPR 0, but since it is based on SL 0 with no risk reduction, we can safely ignore it here.

An interesting point is that there is no incentive to move beyond maturity level 3 since it will not affect the SPR.

Table 4. Security protection rating.

SPR	Security Level	Maturity Level
SPR1	SL 1—protection against unintentional/ accidental misuse	ML 3/4 practiced/improving (same for all SPR)
SPR 2	SL 2—intentional, few resources, general skill, low motivation	
SPR 3	SL 3—intentional, sophisticated, moderate resources, IACS specific knowledge, reasonable motivation	
SPR 4	SL 4—intentional, sophisticated, extensive resources, IACS-specific, high motivation	

5. IEC 62443 and Its Application

The IEC 62443 standard takes a holistic view on the cybersecurity of IACS, covering the technical, procedural and people aspects, for the different roles involved in the supply chain. These roles include the product supplier, service provider, and asset owner. The standard has been in development since 2009, and an overview of its different parts was presented in Table 1. We now proceed to introduce a few selected concepts from the standard.

5.1. Application of Security Levels

Based on our earlier survey [21], the IEC 62443 standard is the only quantifiable approach currently in use for determining and validating security levels (SLs) in IACS.

In this paper, we use the IEC 62443 definitions of Security Level (SL), and specifically the definitions shown in Table 5. However, the definition of SLs can vary slightly between different sources, and we, therefore, start our discussion of SLs by referring to some of these definitions. The IEC 62443-3-3:2013 [16] definition of SL is “measure of confidence that the IACS is free from vulnerabilities and functions in the intended manner”. The IEC 62443-3-2:2020 [14] uses almost the exact same definition, but replaces “IACS” with “SuC”. The Global Cybersecurity Alliance [22] uses the same definition, but also includes zones and conduits, in addition to SuC.

What further complicates the matter is that Annex A of IEC 62443-3-2 defines the four numeric SLs as protection against violations from increasingly sophisticated attackers, as shown in Table 5. These definitions, focusing on level of protection, are also in line with Gordon [23] and Kobes [24], who state that “security level values express the security capabilities of the automation solution”.

Table 5. SLs as defined in IEC 62443-3-2:2020 [14] Annex A.

SL	Description
1	Protection against casual or coincidental violation
2	Protection against intentional violation using simple means with low resources, generic skills and low motivation.
3	Protection against intentional violation using sophisticated means with moderate resources, IACS specific skills and moderate motivation.
4	Protection against intentional violation using sophisticated means with extended resources, IACS specific skills and high motivation

The IEC 62443 also defines four contextual SLs, as shown below (in previous versions of the standard, there were three types of security levels: SL-C, SL-T, and SL-A (achieved security level)):

SL-C: Capability security level, i.e., the SL that individual components or systems can provide when properly configured.

SL-T: Target security level, i.e., the required SL based on a risk assessment. SL-T is first identified for individual zones, but can be allocated to individual systems and to conduits.

SL-I: Implemented security level, i.e., the actual security level of a specific component or system, considering how it has been configured.

SL-O: Operational security level, i.e., the actual security level of a component, system, or zone, considering the state of the actual measures in place at the time assessed in operation.

For the discussion in this paper, SL-T is the most relevant.

Determining SL-T is part of the cybersecurity risk analysis step zone and conduit requirement (ZCR) 5.6 [14]. A corporate risk matrix with tolerable risk is used as input for the requirement. The standard does not detail how the SL shall be established and instead states that there is no “prescribed method for establishing SL-T”, but companies often apply their own calibrated risk matrix for the purpose. One approach to this risk assessment as described in IEC 63443-3-3 [16] is shown in Figure 2 [25].

Having different SL-T requirements for zones means that many zones must apply distinct sets of security requirements. It could have been tempting to decide on one common SL-T for the whole system to avoid the problem of connecting zones with different SLs. However, with such a strategy, the highest SL-T of a zone would be inherited for all other zones, even if they are not exposed to the same risks. Such a strategy is not recommended, as the choice of security measures and their follow-up would be unnecessarily expensive and inconvenient, for example, requiring multi-factor authentication for equipment that is incapable of supporting it. As we discuss below, this would also not remove the requirement for control mechanisms at conduit endpoints, as, otherwise, the entire system would end up being a single zone, which is intractable.

5.2. Application of Zones

IEC 62443 has introduced *zones* and *conduits* as means to group assets in a network architecture that share common security requirements. Unfortunately, IEC 62443 does not limit itself to only one definition of the term zone, and variants have been introduced with new parts of the standard being published, as shown in Table 6. A conduit is a special case of a zone, where the primary role is to group assets that play a role in connecting two or more zones. Although IEC 62443-2-1 requires the segmentation of networks into zones, it does not clearly define their distinction from conduits other than by providing an example

(in the standard's Section A3.3.4.2) of how segmentation and assignment of conduits may be undertaken based on the Purdue level.

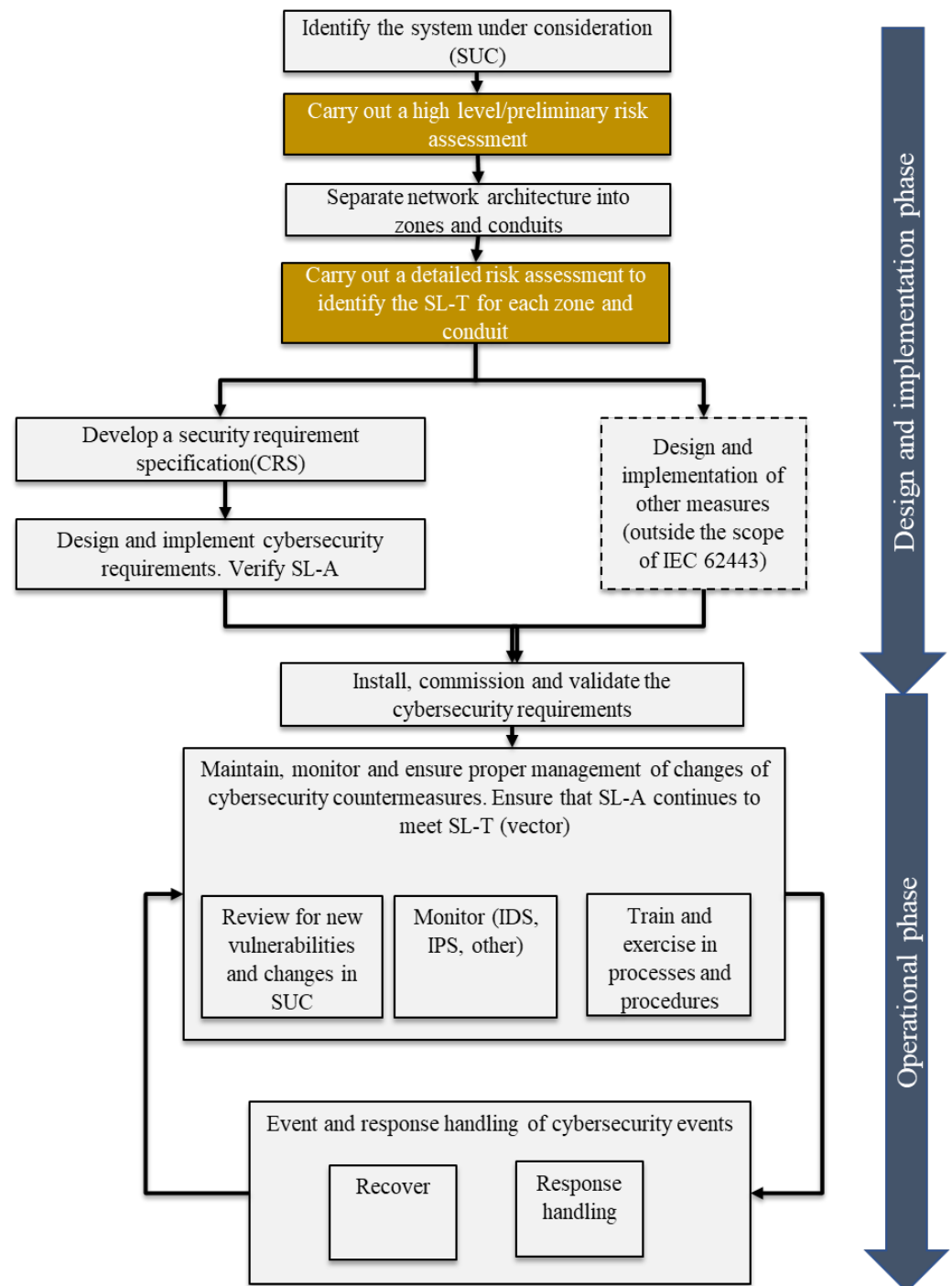


Figure 2. Risk assessment according to IEC 63443-3-3.

The cyber-risk assessment determines to what extent zones have similar boundaries as the Purdue model layers. For example, layer 2 with human machine interface may end up with the same security requirements, while layer 1 may decide on stricter security requirements for safety controllers compared to process controllers. Plants with large outreach and many distributed systems may group assets that belong to more than one layer into the same zone. A specific zone can therefore include some or all assets within a layer, or alternatively include assets in several layers.

Table 6. The definition of a *zone* in the different parts of IEC 62443.

Standard	Definition
62443-1-1 (2009)	Zone: grouping of logical or physical assets that share common security requirements. NOTE: A zone has a clear border with other zones. The security policy of a zone is typically enforced by a combination of mechanisms both at the zone edge and within a zone. Zones can be hierarchical in the sense that they can be comprised of a collection of sub-zones.
62443-3-2 (2020)	Zone: grouping of logical or physical assets based upon risk or other criteria, such as criticality of assets, operational function, physical or logical location, required access (for example, least privilege principles) or responsible organization. NOTE: Collection of logical or physical assets that represents partitioning of a system under consideration on the basis of their common security requirements, criticality (for example, high financial, health, safety, or environmental impact), functionality, logical or physical (including location) relationship.
62443-3-3 (2019)	Zone: grouping of logical or physical assets that share common security requirements. NOTE: A zone has a clear border. The security policy of a zone is typically enforced by a combination of mechanisms both at the zone edge and within the zone.
62443-4-2 (2019)	
62443-4-1 (2018)	Zone: collection of entities that represents partitioning of a System under consideration on the basis [of] their functional, logical and physical (including location) relationship. NOTE: Zones are often created on the basis of common security requirements, criticality (e.g., high financial, health, safety, or environmental impact), functionality, logical or physical (including location) relationship.

In this article, we will use the following definition based on 62443-1-1 [1]:

A *Zone* is a grouping of logical or physical assets that share common security requirements.

5.3. Scope and Application of Conduits

Many professionals have an intuitive understanding of what a conduit should be but struggle when trying to detail what to include within its boundary. A conduit is referenced as a special type of zone by IEC 62443-1-1 [1]. The definition has been slightly modified over time, and variants therefore exist across the parts of the IEC 62443 standard, as listed in Table 7. In summary, we can say that a conduit is a grouping of communication assets or channels that secures the transition between systems placed in different zones (see Figure 3). While IEC 62443-1-1 [1] has a separate section dedicated to conduits, the other parts reference conduits and zones as if the same requirements and practises apply to both. IEC 62443-1-1 mentions physical communication assets such as wires, routers, and network management devices as typical assets within a conduit, while examples in other parts of the standard seem to widen the scope to also include end point connections. In this paper, we suggest excluding the endpoints and define the conduit as follows:

A *conduit* comprises the data flows that traverse a set of network devices that route and restrict the data flows according to their configuration

We illustrate this in Figure 3. The configuration of the network devices is handled in a separate configuration zone, a concept elaborated-on in more detail later in this paper. As our definition explicitly refers to restricting data flows, physical media is not considered a conduit, except in the very specific case of a point-to-point connection that is completely under the control of the operating organization.

Table 7. The definition of a *conduit* in the different parts of IEC 62443.

Standard	Definition
62443-1-1 (2009)	Conduit: logical grouping of communication assets that protects the security of the channels it contains. NOTE: This is analogous to the way a physical conduit protects cables from physical damage.
62443-3-2 (2020)	Conduit: a logical grouping of communication channels that share common security requirements connecting two or more zones. [the standard defines a channel as “specific logical or physical communication link between assets”, with the associated note “A channel facilitates the establishment of a connection”].
62443-3-3 (2019)	Conduit: logical grouping of communication channels, connecting two or more zones, that share common security requirements. NOTE: A conduit is allowed to traverse a zone as long as the security of the channels contained within the conduit is not impacted by the zone.
62443-4-2 (2019)	

In contrast to conduits, zones are more extensively elaborated. For example, IEC 62443-3-2:2020 [14] includes well-defined examples of equipment and systems to be placed in separate zones, and IEC 62443-3-3:2019 [16] identifies the necessary requirements for how a zone should be configured to fulfil a given SL-T. Deciding on the SL-T of a conduit is not that straightforward, as a conduit may connect zones with different SL targets or connect zones with the same SL-T but where restricted data flow is still needed and security measures must be implemented. For example, an Open Communication Platform (OPC) server in one zone exchanging data with an OPC host in another zone requires a conduit to route traffic to these and no other other endpoints, irrespective of the SL-T of the zones. Furthermore, we posit that a host-to-host Transport Level Security (TLS) connection is not inherently a conduit when you (as an organization) do not control both endpoints.

Given that a conduit is a special type of zone, one can assume that many of the requirements applicable to zones are also applicable to conduits. Even so, it seems reasonable to investigate what makes them special and what the implications are.

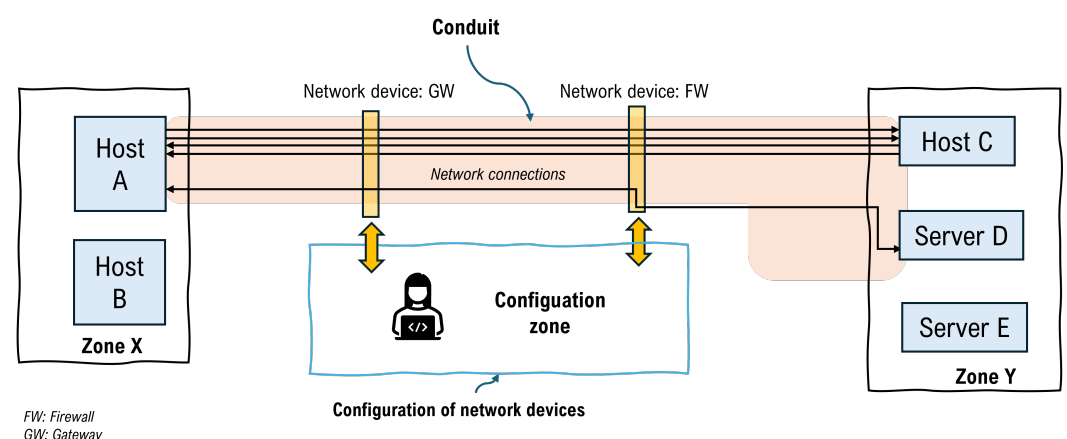


Figure 3. Security conduit: collection of data flows that share common security requirements.

6. General Recommendations for the Allocation of Assets to Zones and Conduits

The IEC 62443 standard has documented specific Zone and Conduit Requirements (ZCRs), and the process of creating zones and conduits is defined in ZCR 3 in IEC 62443-3-2:2020 [14]. The overarching principle for dividing an IACS into zones and conduits is the risk assessment (Requirement ZCR3.1). However, based on our interaction with industry representatives [12], there seems to be some confusion and differences in opinions about what network devices to place in a conduit as opposed to in a zone. Therefore, we are proposing some guiding principles to make the distinction clearer and practical. The principles are:

- A conduit identifies a collection of data flows following the same connection path between two zones (cf. Definition 3.1.3 in IEC 62443-3-2:2020 [14]).
- The network devices involved in realizing the conduit have an SL requirement, and we will thus assign the SL of the configuration zone (see below) as the SL of the conduit.
- The same network device can be used to realize one or more conduits, cf. [5]. This requires clear separation of the implemented conduits (Requirements ZCR 3.1-ZCR 3.6). The *configuration interface* of this network device will have an SL requirement determined by the highest SL requirement of a connected zone (Requirement ZCR 5.6).
- Since network devices are involved to set up conduits among several zones, it seems meaningful to introduce a new type of zone defined as a conduit configuration zone (Requirement ZCR 3.6).
- The configuration zone should, because of its location within the OT system, be managed by the OT cybersecurity team, and not by IT (Requirement ZCR 3.2).

Following this, we assume that a conduit and the associated network device configuration zone(s) have two main responsibilities:

- Protection of zones from each other, by dropping all unintended connections between zones.
- Protection of the availability, integrity and confidentiality of allowed connections between zones.

Based on these principles, we believe that communication assets connecting zones should be split into a data plane, which we consider to be the conduit, and a control plane, which is managed through the different network device configuration zones (see Figures 4 and 5). As an example, a firewall typically consists of a set of rules applied to incoming traffic, and an interface/application for managing and defining such rules. The rules will be applied to the communication in the data plane, while the changing, adding, and deleting of rules will happen through the interface placed in the network device configuration zone. One common misconception we have observed in the field is the belief that hosts in the zones that are connected by the conduit in this manner would also have access to the configuration zone, but this is not the case.

Another example can be that of a Virtual Private Network (VPN) set up between two routers in different zones. In this example, we believe that the conduit should be the data pipe set up by routing rules along the way between the two zones, and the VPN endpoints providing encryption. The network device configuration zones will include the software used to establish and configure the VPN, along with the configuration interfaces for any network devices between the two zones. In the case of a physical level data diode, this will not be part of any network device configuration zone, assuming that it cannot be configured in any way. The requirement to ensure separation of conduits implies that mechanisms that do not offer protection outside the sphere of influence of the configuration zone cannot be used; e.g., where the conduit traverses a network segment with general

access, a simple VLAN tagging mechanism without cryptographic protection will not offer sufficient protection.

The standard does not explicitly state that it is necessary to split parts of the system with same SL into multiple zones, but in practice, there will be multiple zones with the same SL, due to network complexity.

We illustrate these concepts in Figure 4. Zone A and B are both connected to a router, and communicate through a conduit set up by this router. The router is managed by a separate workstation through an interface which is not accessible to the other zones, and this workstation and the internal mechanisms of the router represent the configuration zone.

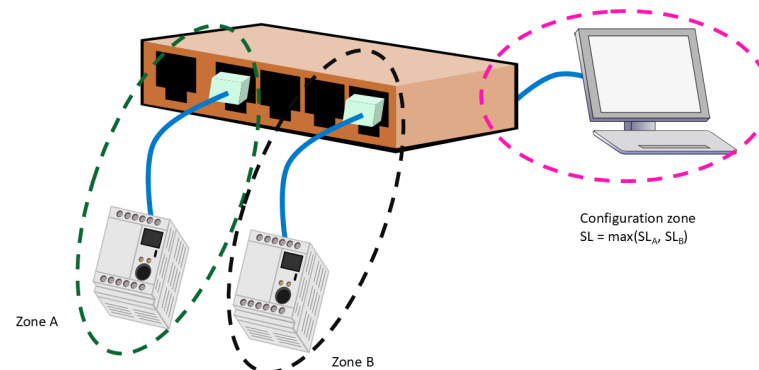


Figure 4. Minimal example of zones connected through router (each zone surrounded by a different colour).

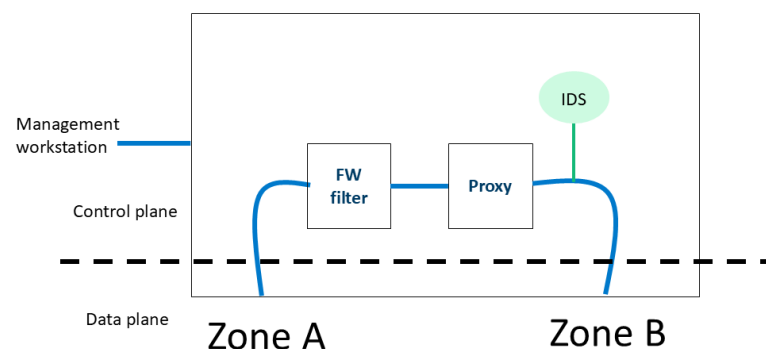


Figure 5. Minimal example of conduit with security mechanisms implemented in the router.

The security mechanisms used to protect the conduit will depend on the security requirements; in our simple example in Figure 5 (which illustrates the inner workings of the router in Figure 4), we apply rule-based filtering plus proxy functionality, and an Intrusion Detection System passively analyses the traffic. Additional mechanisms could include TLS inspection, logging, and remote desktop functionality with whole-session logging (in principle, video recording of a remote desktop session).

Using these principles, the conduit will be reduced to a data pipe which does not have any interface or functionality to secure by itself, since this is moved to dedicated configuration zones.

7. Securing Conduits Connecting Zones with Different SLs

As stated in ZCR 5.6 in IEC 62443-3-2:2020 [14], an SL shall be allocated to zones and conduits. As illustrated in Figure 6, a control mechanism needs to be in place as part of a conduit, both when the two zones have the same SL, and when one zone has a higher SL than the other. In this section, we propose a process for securing a conduit, and the associated network device configuration zones, when the conduit is connecting zones with

potentially different SLs. We express the process in the form of a flow chart (Figure 7), and the steps involved in the process are as follows:

1. In the case that the involved zones have different SLs, we assign the highest SL of all connected zones to the network device configuration zones. We account for the scenario where a previously analysed conduit has resulted in a higher SL for the network device configuration zones.
2. List all data flows and communication channels that are traversing the conduit.
3. Evaluate one by one whether any of the data flows perform write operations from a zone with lower levels of criticality or lower integrity requirement to zones with higher levels of criticality or integrity requirements. Note that “lower level of criticality” most often will imply a lower SL, but this need not always be the case.
4. If this is the case for the data flow under consideration, we assess the potential risk (step 4) if this data flow is compromised by an attacker. If necessary, we implement suitable countermeasures. Examples of countermeasures may include proxy servers limiting what interfaces the zone exposes, or intrusion detection systems flagging suspicious traffic (see Figure 5).
5. Check if there are remaining data flows that have not been evaluated. If there are data flows that have not been evaluated, we return to step 3. Otherwise, the process terminates.

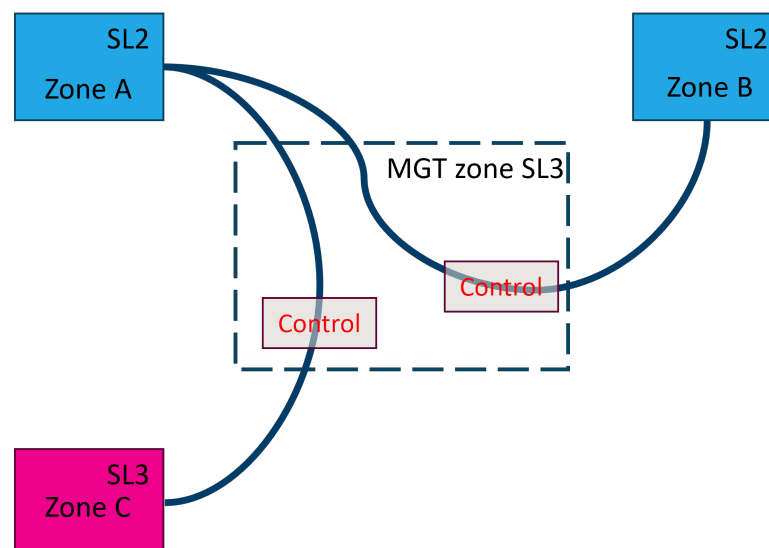


Figure 6. Different zones with varying security levels (cyan for SL2 and pink for SL3).

The management of a conduit is needed regardless of SL-T assigned to the connecting zones. However, the necessity of a configuration zone becomes more evident in situations where a conduit connects zones with different SL-Ts, in particular when the direction of the data exchange is required from a zone with a higher SL-T requirement to one with a lower SL-T. We reason that these network device configuration zones will need to have an SL equal to the highest SL of the zones they are tasked with protecting.

This approach may in some ways be different from the IEC 62443 standard [1], which seems to cater for scenarios where the conduit has a lower SL than the zone. In this case, the conduit is labelled as untrusted, according to part 1-1 (2009) [1]. Following this scenario where the conduit is untrusted, the communication security becomes the responsibility of the individual channel. However, we question the usefulness of implementing a conduit in the first place if the channels passing through it will have to provide their own security.

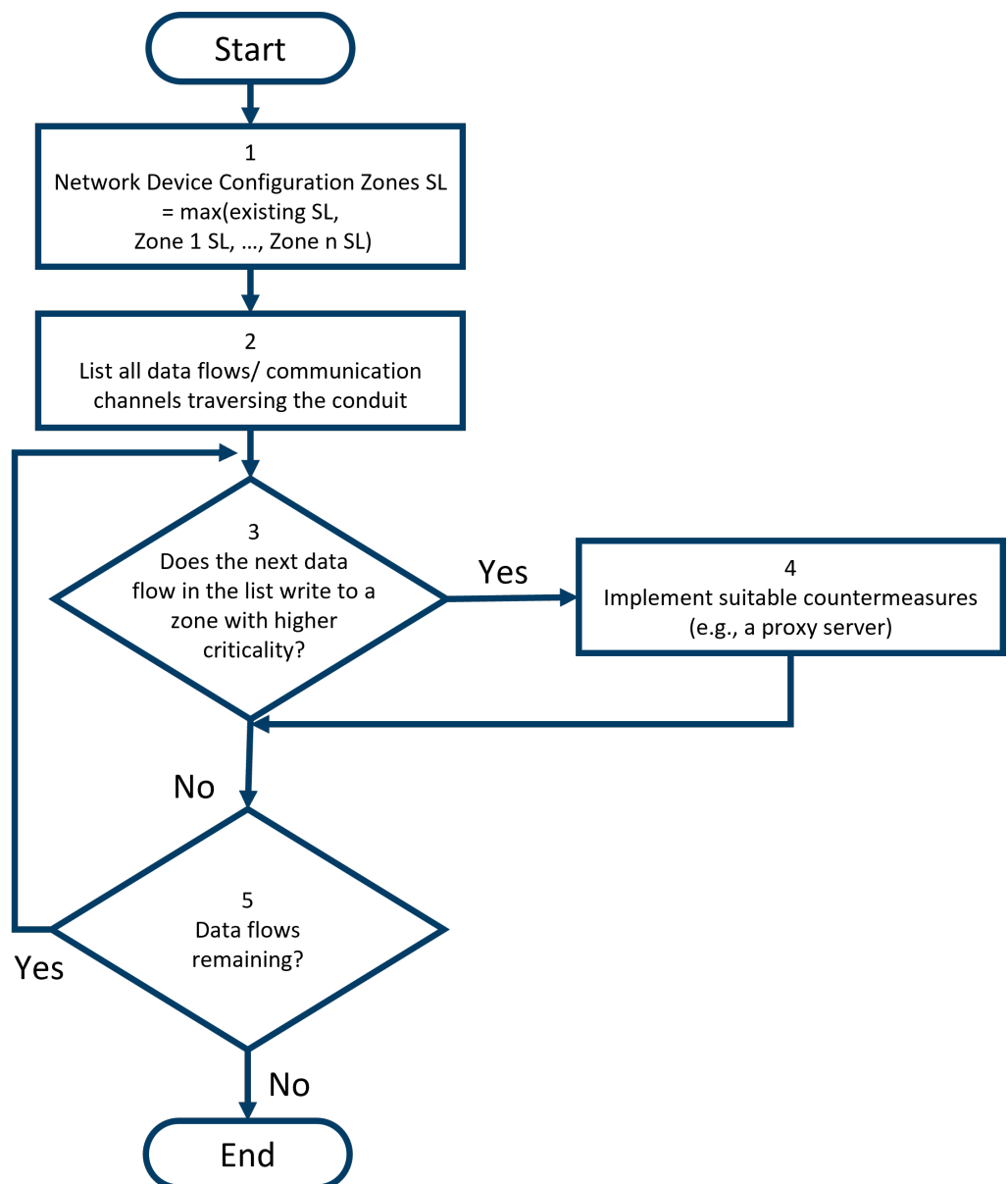


Figure 7. Flowchart for securing conduits between zones.

With our approach, and in line with the commonly accepted philosophy for ICS security where availability and integrity are regarded as more important than confidentiality, we believe that the network device configuration zones should ensure that the availability and integrity of higher SL zones cannot be compromised from lower SL zones. We note that this may imply further security controls in addition to segmentation and boundary protection, as exemplified in Figure 5. When discussing zones and conduits, much of the security discussion tends to revolve around such security controls. While segmentation and boundary protection are efficient security controls, a discussion of the security of zones and conduits must not overlook the aspect of what trust is placed in the data flowing through conduits and between zones. As an example, we can assume to have a server in an SL 1 zone, and a client in an SL 4 zone. While segmentation and boundary protection are suitable for protecting against unintended connections, these may not protect against misuse of legitimate connections.

Similarly, while a VPN connection will protect the confidentiality and integrity of data transmitted across the network, it will not protect against an attacker who has obtained a foothold on the host where the VPN connection originates.

To also defend against these scenarios where an attacker is able to exploit a legitimate connection, it may be necessary to set up intrusion detection functionality on the network devices implementing the conduits, or other methods for detecting or preventing malicious activity (see Figure 5).

8. Securing Conduits Connecting Zones with the Same SLs

When connecting zones with the same SL, it is tempting to conclude that no further controls are necessary, but that would be an overly hasty conclusion.

A case worth considering is where there are two zones with same SL-T, where PCS and utilities are placed in one zone, and SIS systems (ESD, PSD, F&G) are placed in the other zone. Regulatory requirements (Havtil, FR §§ 32-34) [26] state that safety systems must not be negatively impacted by other systems (such as PCS). NORSOK I-002 [27], however, states the following regarding SIS-PCS communication: “The control network design shall allow for authorized communication between SIS and other networks if applicable” (Section 8.1.5.5 in the standard). The term “segment” is defined in IEC 61918 [28] as a trunk-cable section of a network that is terminated at both ends by its characteristic impedance. A note explains that segments are linked together by repeaters within a logical link and by bridges to form a network. In other words, segments are network sections, and therefore not overlapping with the term zone. However, a zone may cover one or more network segments.

An unrestricted connection of two zones with the same SL-T would effectively mean that the two zones would devolve into one big zone, and the situation could quickly go out of control. This implies that conduits connecting zones with the same SL-T may be subject to restrictions. Communication between the two zones (at the same SL) will be restricted to communication required for the function/purpose of the IACS. The restrictions are implemented by the conduit.

9. Practical Challenges of Using Zones and Conduits

In this section, we highlight what we perceive to be challenges with using zones and conduits in practice.

In addition to being a grouping of assets, a zone shall have a set of attributes, according to IEC 62443-1-1 (2009) [1]. These attributes are: security policies, asset inventory, access requirements and controls, threats and vulnerabilities, consequences of a security breach, authorised technology (i.e., a dynamic list of technologies allowed and not allowed in the zone), and a change management process. An aspect of this which should not be overlooked is to what extent this is scalable. As an example, an oil and gas installation may implement 30–50 zones; for cases where a company has many installations, the number of zones quickly grows large. Another example is the Industrial Automation Security Design Guide 2.0 from Cisco, introduced in Section 2, which speaks of scenarios with up to 400 area zones.

We would further argue that the approach of listing threats and vulnerabilities for each zone is problematic for three reasons: it is economically infeasible, it has previously shown to offer limited value for the effort invested, and by the time an installation is in operation, the list developed during the design phase may already be outdated.

Regarding the allocation of SLs to zones and conduits, we believe it would be beneficial with more guidance regarding how the overall architecture should influence the selection of the SL for a specific zone or conduit. If one fails to take advantage of the fact that zones in lower parts of the Purdue model are typically protected by zones higher up in the Purdue model, the result may be overly expensive and inefficient security. As an example, the most critical components are typically at the bottom of the Purdue model,

and consist of embedded devices with limited features. In cases where these are of high criticality, there have been attempts in the industry to give these high SL values (SL-3 or SL-4), with the result of a lot of non-compliance due to missing features, or due to undesirable connectivity with other components. Provided that the Purdue model is properly implemented, the embedded devices on the bottom of the model are significantly protected by the surrounding networks and components, and should be left with limited responsibilities to protect themselves. Enforcing large numbers of requirements on embedded devices will push the suppliers to replace these devices with more standardized computer architectures and operating systems, to fulfil the requirements. This is not desirable as it leads to devices with increased need of anti-malware solutions, regular/frequent patching etc., which is undesirable for devices with high availability and high integrity demands.

A discussion of zones and particularly conduits should also include a discussion of communication channels, as a conduit is defined as a logical grouping of communication channels. The channel is, in turn, a specific communication link established between assets. We are of the opinion that concepts such as conduits, channels, communication links, sub-conduits, and sub-zones could benefit from clearer definitions, demarcation, and more examples of implementation. There should also be a clear justification in terms of added value for introducing additional concepts and definitions.

Lastly, we believe that ensuring consistent definitions of such terms as zone, conduit and SL across the different parts of the IEC 62443 standards would be beneficial for the users of the standard.

10. Conclusions

In this article, we have investigated practical aspects of assigning security levels (SLs) to industrial automation and control systems, and examined the details of conduit architecture and practical considerations of connecting zones with different SLs. The ideas and proposed principles presented in our earlier paper [6] were intended as a first proposal to the IACS community. This article has significantly amended and extended the earlier paper.

Based on the IEC 62443 standard, we define zones and conduits as follows:

A zone is a grouping of logical or physical assets that share common security requirements

A conduit is comprised of the data flows that traverse a set of network devices that route and restrict the data flows according to their configuration.

Motivated by the widespread use of the zones and conduits paradigm, we propose principles for conduit and zone architecture and a pragmatic process for connecting zones with potentially different SLs. This process is expressed in the form of a flow chart. Lastly we highlight some key challenges with using the zones and conduit paradigm in practice.

The research questions outlined in Section 3 have been answered as follows:

- Should a conduit be limited to connecting two, and not several, zones?
 - Operational requirements mandate that a conduit should be just between two zones, as this is fundamental to sufficient control.
- Is the SL requirement of a conduit derived from the SL requirements of the connecting zones only, or are other factors contributing?
 - We conclude that the concept of having an SL assigned to the conduit is less useful, but to the extent that it should be used, it should be based on the SL of the highest connecting zones.

- What are the practical implications of having SL requirements in relation to a conduit?
 - Our proposal of designating a conduit configuration zone with the highest SL of all the conduits it manages is a pragmatic approach to handling SL requirements for conduits.

11. Further Work

The principles enumerated in Section 6 still need to be further motivated, tested and validated in discussion with the industry and in real world use cases. One particular aspect which we believe can benefit from further study is how to best secure connections between zones with different SLs. This can range from outlining specific recommendations for firewalls and intrusion detection deployment, to developing methods for detecting and preventing misuse of compromised legitimate connections, potentially by relating communication traffic to observed anomalies in the underlying process being controlled. This should be coupled to practical employment of the Security Protection Rating scheme [17], including studying the impact of the missing differentiation of Maturity Level 3 and 4 in the calculation of the SPR value.

Concretely, we are currently exploring a follow-up research project where a formal case study will validate our principles using an action research paradigm [29]. Part of such a case study would also be to establish measurable indicators related to SL validation and SPR calculation, and create concrete design patterns for creating zones and conduits in different topologies, taking the different levels of the Purdue model into consideration. Additionally, it would be natural to produce corresponding checklists or implementation templates, and discuss potential integration challenges with legacy systems.

In future work, we hope to apply our approach to zones and conduits in new industries such as:

- Power generation, transmission and distribution;
- Chemical manufacturing industries;
- Automotive industries.

The study of zones and conduits in such new industries should also take into account challenges of Industry 4.0, Industrial Internet of Things (IIoT), and the dynamic nature of Software Defined Networking, as problematized by Leander et al. [3]. Based on early work in other projects [30], we believe that new I4.0 standard Asset Administration Shell (AAS) could play a role in dealing with such complexity and scalability issues, but that security implication of AAS will need to be studied carefully. In this context it could also be natural to compare how our principles based on IEC 62443 align with NIST's Cybersecurity Framework [31]. Our stance is that it is primarily the "Identify" and "Protect" functions that are relevant for zones and conduits; the former for identification of assets, performing of risk assessment and SL allocation, and the latter for implementing the required security controls.

Author Contributions: Conceptualization, M.G.J. and L.H.F.; methodology, M.G.J. and M.A.L.; investigation, M.G.J., L.H.F., M.A.L., K.B., R.L., F.G. and C.T.; resources, M.A.L. and M.G.J.; writing—original draft preparation, M.G.J., L.H.F., F.G. and M.A.L.; writing—review and editing, M.G.J., C.T., M.A.L., K.B., R.L. and F.G. All authors have read and agreed to the published version of the manuscript.

Funding: This research was funded by the Research Council of Norway through the Cybersecurity Barrier Management project, grant number 326717. The APC was funded by MDPI.

Institutional Review Board Statement: Not applicable.

Informed Consent Statement: Not applicable.

Data Availability Statement: The original contributions presented in this study are included in the article. Further inquiries can be directed to the corresponding author.

Acknowledgments: The research in this paper was supported by the Research Council of Norway through the Cybersecurity Barrier Management project (grant No. 326717). We are grateful to the CBM advisory committee for their insightful comments and discussion.

Conflicts of Interest: The authors declare no conflicts of interest. The funders had no role in the design of this study; in the collection, analyses, or interpretation of data; in the writing of the manuscript; or in the decision to publish the results. Author Roald Lygre was employed by the company AkerBP, and author Fredrik Gratte was employed by the company Atina. The remaining authors declare that this research was conducted in the absence of any commercial or financial relationships that could be construed as potential conflicts of interest.

Abbreviations

The following abbreviations are used in this manuscript:

ALG	Application Layer Gateway
APC	Article Processing Charge
ESD	Emergency ShutDown
F&G	Fire & Gas
FR	Functional Requirement
IACS	Industrial Automation and Control System
ICS	Industrial Control System
NIST	National Institute of Standards and Technology
PSD	Process ShutDown
SIS	Safety Instrumented System
SOC	Security Operations Centre
SL	Security Level
SL-C	Capability Security Level
SL-I	Implemented Security Level
SL-O	Operational Security Level
SL-T	Target Security Level
ZCR	Zone and Conduit Requirement

References

1. IEC/TS 62443-1-1:2009; Security for Industrial Automation and Control Systems—Part 1-1: Terminology, Concepts and Models. IEC: Geneva, Switzerland, 2009.
2. DesRuisseaux, D. *Practical Overview of Implementing IEC 62443 Security Levels in Industrial Control Applications*; Schneider Electric Whitepaper: Rueil-Malmaison, France, 2018.
3. Leander, B.; Čaušević, A.; Hansson, H. Applicability of the IEC 62443 standard in Industry 4.0/IIoT. In Proceedings of the Proceedings of the 14th International Conference on Availability, Reliability and Security, Canterbury, UK, 26–29 August 2019.
4. Kern, M.; Taspolatoglu, E.; Scheytt, F.; Glock, T.; Liu, B.; Betancourt, V.P.; Becker, J.; Sax, E. An Architecture-based Modeling Approach Using Data Flows for Zone Concepts in Industry 4.0. In Proceedings of the 2020 IEEE International Symposium on Systems Engineering (ISSE), Vienna, Austria, 12 October–12 November 2020; pp. 1–8. [\[CrossRef\]](#)
5. Schlehuber, C.; Heinrich, M.; Vateva-Gurova, T.; Katzenbeisser, S.; Suri, N. A Security Architecture for Railway Signalling. In *Computer Safety, Reliability, and Security SAFECOMP 2017*; Lecture Notes in Computer Science; Tonetta, S., Schoitsch, E., Bitsch, F., Eds.; Springer: Berlin/Heidelberg, Germany, 2017. [\[CrossRef\]](#)
6. Flå, L.H.; Lundteigen, M.A.; Gratte, F.; Jaatun, M.G. Implementation of Zones and Conduits in Industrial Control and Automation Systems. In *Proceedings of the International Conference on Cybersecurity, Situational Awareness and Social Media*; Jaatun, M.G., Onwubiko, C., Rosati, P., Rege, A., Hindy, H., Erola, A., Bellekens, X., Eds.; Springer: Singapore, 2025; pp. 367–382.
7. Williams, T.J. The Purdue enterprise reference architecture. *Comput. Ind.* **1994**, *24*, 141–158. [\[CrossRef\]](#)
8. ISA 84.00.01-2004; Part 1 (IEC 61511-1 Mod)—Functional Safety: Safety Instrumented Systems for the Process Industry Sector—Part 1: Framework, Definitions, System, Hardware and Software Requirements. ISA: Durham, NC, USA, 2004.

9. Chapter: Segment the Network into Smaller Trust Zones. In *Industrial Automation Security Design Guide 2.0*; Cisco: San Jose, CA, USA, 2023.
10. ICLC TS 50701:2023; Railway Applications: Cybersecurity. CENELEC: Brussels, Belgium, 2023.
11. Soderi, S.; Masti, D.; Hämmäläinen, M.; Iinatti, J. Cybersecurity Considerations for Communication Based Train Control. *IEEE Access* **2023**, *1*, 92312–92321. [CrossRef]
12. CDS-Forum—Industry Forum for Cybersecurity of Industrial Automation and Control Systems. 2025. Available online: <https://cds-forum.com/> (accessed on 5 March 2026).
13. Cybersecurity Barrier Management. 2021. Available online: <https://www.sintef.no/en/projects/2021/cybersecurity-barrier-management/> (accessed on 5 March 2026).
14. IEC 62443-3-2:2020; Security for Industrial Automation and Control Systems—Part 3-2: Security Risk Assessment for System Design. IEC: Geneva, Switzerland, 2020.
15. ISA-GCA. Security Lifecycles in the ISA/IEC 62443 Series—Security of Industrial Automation and Control Systems. 2020. Available online: <https://21577316.fs1.hubspotusercontent-na1.net/hubfs/21577316/2022%20ISA%20Website%20Redesigns/ISASecure/PDFs/Miscellaneous%20PDFs/Documents-Articles-and-Technical-Papers/ISAGCA-Security-Lifecycles-whitepaper.pdf> (accessed on 5 March 2026).
16. IEC 62443-3-3:2013; Industrial Communication Networks—Network and System Security—Part 3-3: System Security Requirements and Security Levels. IEC: Geneva, Switzerland, 2013.
17. IEC 62443-2-2 ED1; Security for Industrial Automation and Control Systems—Part 2-2: IACS Security Protection. IEC: Geneva, Switzerland, 2025.
18. IEC 62443-4-1:2018; Security for Industrial Automation and Control Systems—Part 4-1: Secure Product Development Lifecycle Requirements. IEC: Geneva, Switzerland, 2018.
19. IEC 62443-2-1:2010; Industrial Communication Networks—Network and System Security—Part 2-1: Establishing an Industrial Automation and Control System Security Program. IEC: Geneva, Switzerland, 2010.
20. IEC. Understanding IEC 62443. 2021. Available online: <https://www.iec.ch/blog/understanding-iec-62443> (accessed on 5 March 2026).
21. Øien, K.; Hauge, S.; Jaatun, M.G.; Flå, L.; Bodsberg, L. A Survey on Cybersecurity Barrier Management in Process Control Environments. In Proceedings of the 2022 IEEE International Conference on Cloud Computing Technology and Science, Bangkok, Thailand, 13–16 December 2022.
22. ISA Global Cybersecurity Alliance | ISAGCA. Available online: <https://isagca.org/> (accessed on 5 March 2026).
23. Gordon, J. The Essential Guide to the IEC 62443 Industrial Cybersecurity Standards. 2021. Available online: <https://industrialcyber.co/features/the-essential-guide-to-the-iec-62443-industrial-cybersecurity-standards/> (accessed on 5 March 2026).
24. Kobes, P. *Guideline Industrial Security—IEC 62443 Is Easy*; VDE VERLAG GMBH: Berlin, Germany, 2023.
25. Lundteigen, M.A. *TTK4175 Lecture Notes*; NTNU: Trondheim, Norway, 2026.
26. Regulations Relating to Health, Safety, and the Environment in the Petroleum Activities and at Certain Onshore Facilities (The Framework Regulations). 2019. Available online: https://www.havtil.no/contentassets/f18375b7184d4cd68fc1c733b318b3dc/rammeforskriften20_e.pdf (accessed on 5 March 2026).
27. *NORSOK I-002:2021*; Industrial Automation and Control Systems. Standard Norge: Oslo, Norway, 2021.
28. IEC Standard 61918:2018; Industrial Communication Networks—Installation of Communication Networks in Industrial Premises. IEC: Geneva, Switzerland, 2018.
29. Avison, D.E.; Lau, F.; Myers, M.D.; Nielsen, P.A. Action research. *Commun. ACM* **1999**, *42*, 94–97. [CrossRef]
30. Lundteigen, M.A.; Omang, E.; Ottermo, M.V.; Hauge, S.; Lee, S. Industry 4.0 for the process industry: Using OPC UA to implement an information model for follow-up of safety instrumented systems. In Proceedings of the 33rd European Safety and Reliability Conference (ESREL 2023), Southampton, UK, 3–8 September 2023.
31. *The NIST Cybersecurity Framework (CSF) 2.0*; National Institute of Standards and Technology: Gaithersburg, MD, USA, 2024.

Disclaimer/Publisher’s Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.